SPT-Txn Framework

Enterprise Briefing

How to embed compliance permanently into every transaction your institution processes

For: Violet Sky Security Sezc

Presented by Rudi Coetzee, CISSP/ISSAP/ISSMP/CSSLP

IETF Draft: draft-coetzee-oauth-spt-txn-tokens-00

Your Compliance Challenge

The gap between authorization and execution is where risk hides

An AI agent executes a trade on your platform at 2am. Who authorized it, under what scope, on what policy state?

HIGH RISK

A tokenized bond transfers across three jurisdictions. Which AML ruleset applied at the moment of settlement?

AUDIT EXPOSURE

A regulator requests transaction-level evidence for Q4. Your compliance team needs 6 weeks to reconstruct it.

REGULATORY BREACH

Your policy engine goes offline for 4 minutes. Transactions continue. Did any execute outside policy?

UNKNOWN

The Compliance Gap Nobody Has Solved

Policy and transactions exist in separate systems — that's the structural flaw

TODAY

- ✗ Transaction executes in System A
- ✗ Policy check in System B (external overlay)
- ✗ Audit trail reconstructed in System C
- ✗ These 3 systems can fall out of sync
- ✗ Compliance is validated AFTER the fact
- ✗ AI agents can bypass the overlay entirely

WITH SPT-TXN

- ✓ Policy bound to transaction at creation
- ✓ Token carries proof of authorization
- ✓ Cryptographic — not reconstructed
- ✓ Immutable at moment of execution
- ✓ Regulators verify instantly
- ✓ AI agents carry scope-limited tokens

Integration Architecture

Fits into your existing infrastructure — does not replace it

Your Existing Infra

No replacement required

Core banking system · Exchange engine · Payment rails · Smart contracts

SPT-Txn Token Layer

The new compliance envelope

Policy engine (TBAC) · Token issuance & verification · SD-JWT / CWT / Biscuit format support

Regulatory & Audit Layer

Immutable, instantly verifiable

VARA · MiCA · DORA · GENIUS Act · ISO 27001 · FinCEN · FATF

Token formats: JWT / SD-JWT (primary) · CWT (agent-to-agent) · Biscuit (alternative) · Format-agnostic TBAC engine

Zero-Knowledge Privacy Layer

Prove compliance without exposing identity — built into the cryptographic layer

ZK Proofs for Compliance

Privacy by Mathematics

KYC/AML attestations verified without sharing underlying data. Groth16 circuits on BN254 produce 192-byte proofs verifiable in under 5ms. Full compliance evidence — zero PII transmitted.

humanAnchor — Sovereign Identity

SSI — Self-Sovereign Identity

Every transaction chain carries a zkDID commitment to the authorizing human. Self-Sovereign Identity: no intermediary holds your identity data. Accountability without surveillance.

GDPR Article 25 — Privacy by Design

GDPR • EU AI Act Art. 14

Data minimization is structural, not policy. SD-JWT selective disclosure + zkDID commitments + TBAC scope enforcement. Privacy enforced at the cryptographic layer, not the application layer.

ZK stack: Groth16 / BN254 · zkDID commitments · SD-JWT selective disclosure · Nullifier registry for proof replay prevention

Risk Reduction & Business Case

Compliance as infrastructure, not overhead

Regulatory Fine Exposure

Risk Avoided

MiCA fines up to 10% of annual turnover. VARA: license revocation. SPT-Txn provides the audit-ready evidence trail regulators require.

Audit Cost Reduction

Cost Reduced

Transaction-level compliance evidence is generated at the moment of execution. Quarterly audits no longer require weeks of reconstruction.

AI Agent Enablement

Revenue Enabler

Safely deploy autonomous agents with cryptographically scoped authorization. Expand capability without expanding liability.

First-Mover Compliance

Strategic Advantage

Institutions that implement SPT-Txn ahead of regulatory mandates demonstrate leadership — and avoid the compliance sprint when rules tighten.

Regulatory Framework Coverage

One implementation — multi-jurisdictional compliance

MiCA

European Union

EU Markets in Crypto-Assets

Transaction-level audit evidence, consumer protection disclosures, AML binding

VARA

UAE / Dubai

Virtual Assets Regulatory Authority

Authorization chain for VA transfers, custody compliance, CISO attestation support

DORA

European Union

Digital Operational Resilience Act

Immutable operational records, incident classification, third-party risk token tracking

GENIUS Act

United States

US Stablecoin Legislation

Payment stablecoin policy binding, FinCEN-compliant authorization chain

FATF Travel Rule

Global

Financial Action Task Force

Originator/beneficiary data embedded in token, cross-border compliance signaling

ISO 27001

Global Standard

Information Security Management

Cryptographic controls, access control evidence, security-by-design architecture

EU AI Act Article 14 — Built In

Human oversight of autonomous AI — cryptographically enforced, not policy-stated

Human Traceability

Art. 14(1) Satisfied

humanAnchor provides cryptographic proof that a verified human authorized the root transaction. Immutable across every delegation hop. Article 14 requires this. SPT-Txn delivers it.

Bounded AI Authorization

Art. 14(2) Satisfied

Capability Acquisition Tokens (CATs) cryptographically limit what any AI agent can do. Scope monotonicity is enforced by math — no agent can exceed its delegated capability. Ever.

Override & Revocation

Art. 14(4) Satisfied

Token revocation registry enables immediate termination of any agent's authorization with cryptographic proof of revocation timestamp. The kill switch Article 14 mandates.

EU AI Act Article 14 alignment · GDPR Article 25 Data Protection by Design · Hedera HCS tamper-evident audit trail · No PII in audit chain

Why Standards-Track Matters to You

Vendor lock-in vs. open protocol — it's a procurement decision

SPT-Txn is being developed through the IETF — the same body that standardized HTTPS, OAuth, and JWT. Your institution's procurement team should consider: are we buying a proprietary black box, or implementing the emerging open standard?

✓ **No Vendor Lock-In**

Open standard means multiple implementation options. You are not dependent on a single vendor's product roadmap or pricing decisions.

✓ **Regulatory Acceptance**

IETF standards are recognized by global regulators. An IETF-standardized compliance protocol carries significantly more regulatory weight than a proprietary solution.

✓ **Future-Proof Architecture**

Standards evolve through community consensus. Your implementation roadmap aligns with the industry, not one vendor's feature timeline.

✓ **Reference Implementation Available**

Violet Sky Security SEZC provides the certified reference implementation — giving you a supported, production-ready starting point with the protocol authors.

Next Steps

A pilot deployment can be scoped in 30 days

1

Technical Discovery Call

30-min session with your CISO/CTO to map current transaction authorization architecture and identify highest-value integration points.

2

Pilot Scope Definition

Define a single transaction flow (e.g. RWA transfers or AI agent trades) as the pilot. Deliverable: SPT-Txn token issuance + verification for that flow.

3

Proof of Concept

8-week PoC with your engineering team. Output: working integration, compliance evidence sample for your regulatory team to review.

4

Production Roadmap

Define rollout across transaction types with pricing, SLA, and IETF conformance certification pathway.

Rudi Coetzee · rudi@violetskysecurity.com · Violet Sky Security SEZC · Cayman Islands